



Lumi Reading · Security & Privacy Evidence

PR2

Privacy Policy (rewrite)

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT — FOR ADVISER REVIEW

⚠️ PRIVACY/LEGAL-SENSITIVE DRAFT — PRIVACY ADVISER SIGN-OFF REQUIRED BEFORE PUBLISHING

This is a **draft rewrite** of Lumi's public Privacy Policy. It must **not** be published, and the live legal page (`school-admin-web/src/app/legal/privacy/page.tsx`) must **not** be modified, until the appointed Australian privacy adviser has reviewed and signed it off and Nic has approved it. **Do not bump the consent/version constants** on the back of this draft (that is a separate, single re-acceptance step — remediation plan Phase 6.5). This document is not legal advice.

ST4S item: PR2 (privacy policy covers all required content) **Version:** 0.1 — DRAFT for review, not yet signed

Date: 2026-07-24 **Grounded in:** `docs/privacy/PRIVACY_IMPACT_ASSESSMENT.md` ,

`docs/privacy/VENDOR_DATA_FLOW_REGISTER.md` ,

`docs/privacy/APP_8_CROSS_BORDER_DISCLOSURE_LAWYER_BRIEF.md` , and the current live policy **Replaces (on approval):** the live policy last updated 15 July 2026

How to read this draft

The seven required content areas are set out **explicitly and in order** as sections (1)–(7) below, matching the PR2 checklist. Text in **[adviser: ...]** is a drafting note, not policy text, and must be resolved or removed before publication. This draft keeps every factual claim consistent with the current verified data practices; it does not assert any control that is not live (e.g. it does not claim App Check is enforced or that the AI feature is on).

Lumi Privacy Policy (draft body)

Lumi ("Lumi", "we", "us", "our") provides the Lumi Reading Diary app and related services (the "Service") to schools. Lumi handles most information about students **on behalf of, and at the direction of, the school** that enrolls them. We are committed to handling personal information consistently with the **Privacy Act 1988 (Cth)** and the **Australian Privacy Principles (APPs)**.

[adviser: insert the Lumi contracting legal entity name and ABN once confirmed; the APP-entity determination is open — see APP 8 brief §4.]

(1) The kinds of personal information we collect

Account information (teacher, school administrator, or parent/carer):

- name and the role held (parent/carer, teacher, or school administrator);

- a mobile phone number (required for parent/carer accounts, used for sign-in and reminders) and, optionally, an email address;
- for parents/carers, the relationship to the child (e.g. Mum, Dad, Guardian);
- the school and class you are associated with, and the link or school code used to join;
- an optional profile photo and chosen in-app character.

Passwords are managed by our authentication provider (Google Firebase Authentication); we do not see or store your raw password.

Student information (entered by the school and the parents/carers and teachers it authorises):

- the student's name, class and year level, and optionally date of birth and profile photo;
- reading level and the history of reading-level changes;
- reading activity — dates, minutes read, books read, how the child felt about the session, and any notes;
- optional short comprehension voice recordings (only where a school administrator has turned the feature on, confirmed the school will notify families, and chosen a 30, 90 or 365-day deletion period);
- optional photos attached to a reading log;
- messages exchanged between a teacher and a parent/carer about a reading log.

Device and technical information:

- a push-notification token, to deliver reminders and updates;
- app version and device type where needed to operate the Service;
- optional crash reports and limited product-usage analytics, **only** where an adult account holder has enabled that control on that device;
- information you provide when you contact support or send feedback.

We do **not** collect information for advertising, and we do **not** track you across other companies' apps or websites.

(2) How we collect and hold personal information

How we collect it. We collect information directly from the adults who use the Service — when a school provisions staff, when a teacher or parent/carer creates an account and enters reading activity, and when you contact support. A school (and the teachers and parents/carers it authorises) enters student information. We also receive a small amount of technical information from your device (for example, a push-notification token), and — only if you opt in — diagnostic information.

How we hold it. Information is stored using Google Cloud / Firebase infrastructure, with our **primary database and file storage hosted in Australia** (the Sydney `australia-southeast1` region). Information is encrypted in transit and at rest. Access is restricted by authentication and security rules so users can reach only the data they are entitled to: access is role-, class- and family-scoped, and roles are defined by the server, not asserted by the client. The database has point-in-time recovery and deletion protection. Some supporting provider systems operate overseas — see sections (6) and (7).

(3) The purposes for which we collect, hold, use and disclose it

We use personal information to:

- provide the Service — record and display reading activity, progress and achievements;
- enable communication between teachers and parents/carers about a child's reading;
- send reading reminders, achievement and comment notifications, and school announcements;

- operate and secure the Service, and — where an adult has opted in — troubleshoot and improve the app using pseudonymous crash reports or product-usage analytics;
- verify school enrolment and manage access entitlements; and
- respond to support requests and meet legal obligations.

We **disclose** personal information only as needed to run the Service:

- **Within the school community:** a child's reading information is visible to that child's teachers and school administrators, and to the parents/carers linked to the child.
- **Service providers (processors):** we use Google Firebase / Google Cloud (authentication, database, file storage, messaging and, where you opt in, crash reporting and analytics) and an email provider to send transactional email. These providers process data **on our behalf**, on our instructions, under their own security and privacy commitments. A description of our sub-processors is available on request **[adviser: link the approved sub-processor table once published — see PR17 draft]**.
- **Book look-ups:** to fetch book titles and cover images we send **only** a book's ISBN or title to public book databases (such as Google Books and the Open Library). **No student information is sent in these look-ups.**
- **Legal reasons:** where required by law, or to protect the rights, safety and security of users, the public or Lumi.

We do **not** sell personal information and do **not** use it for third-party advertising.

Children's information. Lumi is designed to be used *about* children by the adults responsible for them — schools, teachers and parents/carers — not by young children independently. The school is responsible for ensuring it has the appropriate authority and parental consent to enter student information and to enable optional features such as voice recordings.

(4) How you can access and correct your personal information

You may request access to, or correction of, the personal information we hold about you. Parents/carers can view and update much of their own and their child's information in the app, and schools can manage student records directly. A parent/carer or teacher can permanently delete their own Lumi account from **Settings** → **Account**. Because Lumi holds student information on behalf of schools, a parent/carer who wants a child's **school record** accessed, corrected or deleted should contact the school, or email support@lumi-reading.com. We verify a requester's authority through their existing account or the school contact before acting; legal or school record-keeping requirements may apply.

(5) How to complain, and how we handle complaints

If you have a question about this policy, or wish to make a privacy complaint, contact us at support@lumi-reading.com. We will **acknowledge** your complaint and **respond within a reasonable period**. When handling a complaint we record the requester's identity, authority, the scope of the request, our decision and completion, and we verify authority before making any change. If you are not satisfied with our response, you may contact the **Office of the Australian Information Commissioner (OAIC)** at oaic.gov.au.

[adviser: confirm the target acknowledgement/response timeframes to state here; PIA APP 12/13 requires the response workflow to record identity, authority, scope, decision and completion — reflected above.]

(6) Whether we disclose personal information overseas

Yes — some information is handled overseas. Our primary database, file storage and application processing are in **Australia** (Sydney), but some supporting provider systems operate outside Australia:

- **Account authentication** (Google Firebase Authentication) is processed in the **United States**.
- **Push notifications** are delivered through Apple and Google's **global** messaging services.
- **Transactional email** is sent through our email provider, whose infrastructure is in **North America and the European Union** (and which may process in the United States).
- **Optional** crash reporting and product-usage analytics (only if you opt in) **may be processed outside Australia**.

Where information is handled overseas, we take reasonable steps to ensure it is handled consistently with the APPs, minimise what is sent, and keep child names and content out of the flows that leave Australia wherever possible.

[adviser: this section states an overseas disclosure occurs. The APP 8 reasonable-steps analysis, and whether each flow is a disclosure or a use under Lumi's effective control, is pending your review (APP 8 brief). Confirm the wording of "reasonable steps" and whether any APP 8.2 exception is relied on — the brief advises against relying on a consent-waiver exception for a children's service.]

(7) The countries in which recipients are likely to be located

- **Australia** — primary: the Sydney [australia-southeast1](#) region hosts the main database, user-content storage, application compute and (going forward) ordinary logs.
- **United States** — Firebase Authentication (account identity); the email provider (Twilio, Inc.) may process there; some global platform services and Google's required audit logs.
- **North America and the European Union** — email-provider (SendGrid) infrastructure sub-processors.
- **Global / other** — Apple and Google push-notification delivery, and (only if you opt in) Analytics/Crashlytics, may be processed in other countries where those providers or their sub-processors operate.

We keep a current sub-processor list identifying each provider and the countries where it processes information; it is available on request *[adviser: link the approved PR17 sub-processor table]*.

How long we keep information; push notifications and optional analytics

(Carried across from the current policy for completeness; unchanged in substance, subject to the same adviser review.)

- We keep information while the account/school relationship is active and as needed to provide the Service; access to a student's data is tied to the school's enrolment and annual renewal.
- **Comprehension voice recordings** are kept only for the school's chosen deletion period (30, 90 or 365 days); legacy 7-day settings are still honoured for deletion but cannot authorise new recordings; unconfirmed uploads are removed after 24 hours.
- On account deletion, core school reading events may be retained only in de-identified form so deleting an adult's login does not erase a child's educational record; a minimal completion receipt is kept for 90 days.
- You can turn off push notifications in device settings. Analytics and crash reporting are **off by default** and controlled per device in **Settings → Account → Privacy & diagnostics**. Lumi does not attach a Firebase UID, child identity, school, title, recording, note or detailed reading result to Analytics.

*(An AI-assisted comprehension feature is **not** enabled in production. If it is ever turned on for a school, a separate collection notice will be issued first — see [docs/privacy/AI_EVAL_COLLECTION_NOTICE_DRAFT.md](#) . Do not reference it as a current feature.)*

Evidence index

Policy claim	Evidence
Categories of information collected	PIA §2; live policy §1
AU primary hosting (<code>australia-southeast1</code>), encryption, scoped access	PIA §4; <code>AU_RESOURCE_LOCATION_AUDIT_2026-07-17.md</code> ; <code>ACCESS_CONTROL_POLICY.md</code>
Firebase Auth = US	Firebase DP&S Terms; PIA §3.1; APP 8 brief §5
Push = Apple/Google global	Vendor register (FCM/APNs row); APP 8 brief §5
Email provider = NA/EU/US	<code>vendor-evidence/2026-07-17/README.md</code> ; register (SendGrid row)
Analytics/Crashlytics opt-in, off by default, no Lumi UID	PIA §2/§4; live policy §8
Book look-ups = ISBN/title only, no student data	PIA P-12; <code>DATA_SHARING_AUDIT.md</code> ; live policy §4
Overseas handling occurs; reasonable steps; APP 8 open	APP 8 brief; PIA APP 8 note
Voice retention 30/90/365, legacy 7-day, 24h unconfirmed	PIA §4; live policy §6
Complaints via support + OAIC escalation	Live policy §10; PIA APP 12/13

Known gaps / adviser must confirm

- **APP 8 sign-off is the gating item.** Sections (6) and (7) assert overseas handling; the reasonable-steps analysis, disclosure-vs-use characterisation and any APP 8.2 exception are **pending counsel** (APP 8 brief). Do not publish until confirmed.
- **Legal entity / APP-entity status.** Insert the contracting entity + ABN; confirm whether Lumi is an APP entity and Lumi/school controller split (APP 8 brief §4).
- **Complaint timeframes.** Confirm the acknowledgement/response timeframes to state in section (5).
- **Sub-processor list link.** Section (3), (6) and (7) reference an available sub-processor list — publish/link the approved PR17 table first.
- **Cloudflare / support-mailbox provider** are not yet in the register; if either processes personal information, the overseas-countries list may need updating.
- **Consent re-acceptance is a separate, single step.** Do **not** bump the version constants as part of this draft; that happens once, after this and the sub-processor table land (remediation Phase 6.5).
- **Sign-off.** Requires the privacy adviser's review and Nic's approval; only then may the live `page.tsx` be updated and the `lastUpdated` date changed.